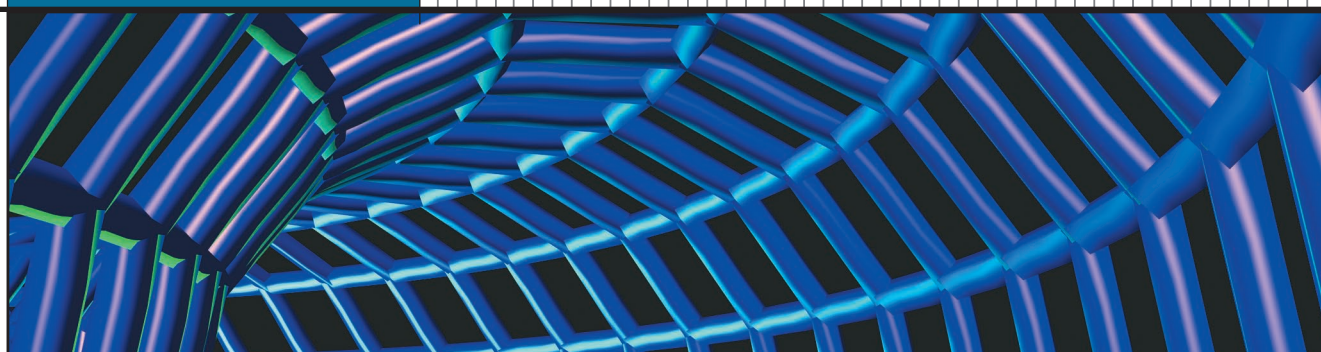




IPv6 Security Challenges

Carlos E. Caicedo and James B.D. Joshi, *University of Pittsburgh*

Summit R. Tuladhar, *Ericsson*

IPv6, the new version of the Internet Protocol, has been developed to provide new services and to support the Internet's growth. An overview of the key security issues outlines the challenges in deploying and transitioning to IPv6.

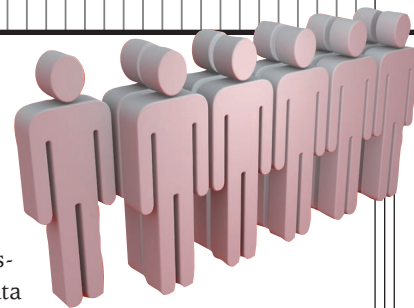
The Internet Protocol version 6 was developed to extend and eventually replace IPv4's capabilities. IPv4 is a key component of the current Internet infrastructure, and IPv6 (IPv5 denotes an unused experimental protocol) is the only available alternative to IPv4 that can support the accelerated growth of Internet-enabled applications and devices. Further, the shortage of IPv4 addresses, which are expected to be used up early in the next decade, and the growing need for an enhanced next-generation Internet protocol that is foundationally secure, have made IPv6 deployment urgent. IPv6 is expected to improve many aspects of IPv4, solve many of its problems, and, most importantly, make the Internet more secure.

Diverse views on IPv6 adoption exist within the networking community, including the view that IPv6 is a failure and provides no significant benefit over IPv4. However, adoption of IPv6 is inevitable. In fact, numerous nations in Europe as well as Asian countries, including Korea, Japan, and China that have limited IPv4 address space have made the migration a national priority. Worldwide IPv6 deployment efforts and awareness are primarily promoted by the IPv6 Forum (www.ipv6forum.com) and its members.

Although the US has been slow in moving toward IPv6, perhaps because of the lack of an urgent need for additional IP addresses and an unclear picture of its economic implications, it has recently ramped up efforts toward this migration. The US Department of Defense (DoD) has taken a lead in this effort by setting up the IPv6 Transition Office at the Defense Information Systems Agency to support and oversee the transition process and mandating its agencies to deploy IPv6. Moreover, due to a requirement by the US Office of Management and Budget, all federal agencies have had IPv6 network backbones since mid-2008.

The US Internet2 network consortium (www.internet2.org) has implemented an infrastructure that supports IPv6 and is mainly used for research. The DoD's Defense Research and Engineering Network is actively working on IPv6 deployment with a focus on secure networking. Other research and private initiatives worldwide are also deploying IPv6 networks to study its benefits and develop new applications. In addition, the global mobile communications systems community has embraced IPv6 by incorporating it as one of the protocols of choice for carrying data traffic in several mobile communication standards specifications (www.3gpp.org/specs/specs.htm).

These developments indicate that the groundwork for a global IPv6 era is near completion. However, several



transition issues and deployment challenges could have potentially severe security implications if not properly addressed.

Even as IPv6's new features will likely generate newer protocol attacks, the older known IPv4-related attacks will morph into new forms. Further, the lack of trained professionals as well as the scarcity of IPv6-related tools for network security analysis and monitoring will lead to slow response times against security attacks, which could exacerbate simple security breaches in massively interconnected IPv6 environments.

In a nutshell, although IPv6 was designed with security in mind, security concerns could hinder its success if adequate efforts and resources are not devoted to fully understanding IPv6-related security issues and vulnerabilities in IPv6-based network infrastructures.

In contrast to IPv4 addresses, which use only 32 bits, IPv6 addresses are 128 bits long.

IPv6 FEATURES

The development of a protocol to replace IPv4 started in the early 1990s.¹ A key motivating factor was the shrinking available IPv4 address space. Network address translation technology helped alleviate this problem by providing Internet access for a large number of computers using a small number of IP addresses. However, to achieve this, a NAT device breaks the end-to-end connectivity between the hosts in the private network and those in the public Internet. Given the rapid increase in the number of networks, IP-addressable devices, and always-on users, NAT faces significant scalability and management challenges in providing end-to-end communication support for applications that require it.

In contrast to IPv4 addresses, which use only 32 bits, IPv6 addresses are 128 bits long. This larger address size allows for the generation of 3.4×10^{38} address values, which should be more than enough for current and future applications, and eliminates the need for address conservation practices such as NAT that IPv4 requires.² IPv6 also supports end-to-end communication, enabling source and destination nodes to interact without intermediate systems such as NAT devices. This feature allows the development of new voice-over-IP, multimedia, and other types of network applications.

Improving network security was another major factor in IPv6 development. Security was not a design consideration in IPv4, and as it became a concern for IP-based

networks, several security solutions such as the Secure Sockets Layer (for secure Web browsing, e-mail, and other data transfers) were developed.

IP Security, a suite of protocols that provide data integrity, confidentiality, and authentication, was introduced later. With Internet key exchange procedures, two entities using IPSec can exchange the necessary parameter information to establish secure communications between them. Because IPSec support is mandatory in IPv6, a fully compliant IPv6 network deployment should provide better security than its IPv4 counterpart.

IPv6 also offers node autoconfiguration. For devices such as a PC, laptop, PDA, or cell phone using an IP-based network, each interface connected to the network must be assigned an IP address. For this task, IPv4 is limited to stateful protocols such as the Dynamic Host Configuration Protocol, which require a server to store a requesting host's configuration information. In addition to supporting stateful autoconfiguration through DHCPv6, IPv6 introduces a simplified stateless autoconfiguration procedure where a node can configure its IP address based only on local information—that is, without contacting a server.

In addition, IPv6 offers better methods for generating manageable routing tables than IPv4. It also provides improved mobility support: Mobile IPv6 is defined as a separate protocol based on the use of IPv6 extension headers and has better authentication and traffic-handling capabilities than MIPv4.

SECURITY ISSUES IN IPv6

Although IPv6 both simplifies and improves IPv4, it poses several significant security challenges.

First, even though IPSec support is mandatory in IPv6, its use is not.¹ Not using IPSec exposes a network to old IP-related attacks as well as attacks related to IPv6-specific features. A working IPSec infrastructure is also difficult to deploy and manage, further reducing IPSec's use.

In addition, some of IPv6's beneficial features have their own security implications that are not yet fully understood. This uncertainty can impact the confidence of stakeholders in making the switch to IPv6.

Further, during the IPv4-to-IPv6 transition and even beyond, both IPv4-based legacy networks and IPv6 networks will likely coexist. In such a situation, the possibilities for network-based attacks will likely increase; hence, securing a network will be more difficult.

Moreover, old security headaches will not completely go away: Some problems that affect IPv4 networks—such

as application-layer attacks, rogue devices, and packet flooding—can also affect IPv6 networks.

Finally, several other new, unanticipated security issues will likely emerge as the hacking community starts actively targeting IPv6 networks.

Reconnaissance attacks

Host probing and port scanning are usually the initial activities an attacker engages in to discover vulnerabilities in a network. In host probing, the attacker tries to identify the hosts connected to a network. Once the hosts are found, the attacker uses port scanning to look for exploitable vulnerabilities.

Some problems that affect IPv4 networks—such as application-layer attacks, rogue devices, and packet flooding—can also affect IPv6 networks.

The potentially huge size of IPv6 subnets makes reconnaissance attacks more difficult, but there are other ways to identify target systems.³ The attacker might find that a network administrator uses a sequential numbering scheme to assign IP addresses to hosts; thus, finding hosts to scan becomes trivial. IPv6's multicast address structure lets an attacker identify groups of key network components, such as all the routers or all DHCP servers for a given network, thereby providing an opportunity to scan these devices' vulnerabilities.

Administrators can use IPsec's security services to reduce packet sniffing—looking at a packet's content—and port scanning activities. The difficulty in scanning posed by IPv6 addressing also makes it hard for an administrator to identify hosts that are either malicious or possible targets for attackers.

Host initialization and associated attacks

Autoconfiguration is an IPv6 feature that lets a node automatically generate an address for each of its network interfaces. This relieves network administrators from the tedium of manually configuring addresses in hosts or maintaining DHCP servers even in large enterprise networks. As many types of devices such as PDAs, TVs, and sensors become IP-enabled, autoconfiguration will eliminate the need to set up a DHCP server for every new type of network.

An IPv6 node can configure its address through either *stateless* or *stateful* autoconfiguration. Stateless autoconfiguration generates the address by combining two pieces

of information: the network prefix, obtained from the routers located in the network segment to which the host is attached; and the media access control (MAC) address, obtained from the node's network interface. Stateful autoconfiguration contacts a DHCPv6 server for the required address and network information.

The Neighbor Discovery Protocol assists the stateless autoconfiguration process. After its address has been configured, a node uses NDP to discover other nodes in the same link. In addition, the protocol lets the node find routers and maintain reachability information on the detected active neighbors. NDP messages are part of the Internet Control Message Protocol for IPv6 (ICMPv6), which also provides functionalities for reporting error messages, performing network diagnostics, and handling multicast memberships.

To generate an interface's network address, a node first sends a *router solicitation* (RS) message to the "all routers" multicast address to find a router and obtain the network prefix value. Once a tentative address has been generated, the node uses duplicate address detection to check that the address is unique. In DAD, the node sends a *neighbor solicitation* (NS) packet with its tentative IP address inside. This packet's purpose is to seek a response from any node that might already have been assigned the newly generated address. If there is no reply to the NS message, the node that generated the address assumes it to be unique and uses it.

When not secured through IPsec, ICMPv6 messages open the door for many attacks, including flooding and denial of service (DoS).⁴ These are possible because any malicious node that generates ICMPv6 packets can easily fool other nodes on a network segment to follow the packet's instructions, resulting in a subversion attack that makes the subverted nodes follow the attacker's wishes. In addition, if the attacker generates a flood of ICMPv6 messages, a victim node or network segment will suffer decreased performance.

Several attacks can only be executed by a node in the network segment where the victim node is also attached. Here, we focus on attacks related to the autoconfiguration process. Figure 1 shows the interactions for some of these attacks.

DoS attack on DAD protocol. In a DoS attack, the attacker makes an organization's network services or resources unavailable to legitimate users. A DoS attack on an IPv6 network can be launched by exploiting vulnerabilities in the DAD procedure. For this, an attacker on the local link waits until a node sends an NS packet. The attacker falsely responds with a *neighbor advertisement* packet, informing the new node that it is already using that address. Upon receiving the NA, the new node generates another address and repeats the DAD procedure; the attacker again falsely responds with an NA packet.

Eventually, the new node gives up without initializing its interface.

Man-in-the-middle attack. When a node A requires the MAC address of another node B, it sends an NS message to the all-nodes multicast address. An attacker on the same link can see the NS message and reply to it with the corresponding NA message, thereby taking over the intended traffic flow between A and B.

Bogus router implantation attack. Routers in IPv6 can use the ND protocol to discover each other's presence and determine their link-layer addresses and prefix information. However, this also lets a malicious node impersonate a network segment's default gateway.³ A receiving node does not validate *router advertisements*. Thus, any node that receives a fake RA updates its communication parameters blindly based on the RA. A malicious node can propagate bogus address prefix information to reroute legitimate traffic to prevent the victim from accessing the desired network.

To avoid this problem, nodes should not be configured to accept all RA messages by default. Instead, they should accept messages only from previously listed routers. An alternate method is to use DHCPv6 to distribute the necessary address prefix information.

Further, if the attacking node is selected as the default router for a particular set of nodes, it can launch a DoS attack by dropping the packets it receives from the victim nodes. It can also launch an MITM attack by peeking at the packets and forwarding their modified versions.

Attacks using routing headers

IPv6 packet structure allows for routing headers, which list the addresses of one or more intermediate nodes that the packets will go through. An attacker can generate specific packets with routing headers to reach hosts that normally would not accept the attacker's traffic. Further, if an end point accepts these headers and follows their routing instructions, trusted nodes could forward malicious packets or the flow of packets could lead to resource exhaustion at the routers, resulting in a DoS attack.

Unfortunately, Mobile IPv6 requires routing headers. Networks with MIPv6 functionality should therefore incorporate mechanisms to securely handle packets with these headers; otherwise, they should not allow these packets.

Multicast-based attacks

An attacker can launch a DoS attack on a multicast group by sending messages to the group address telling

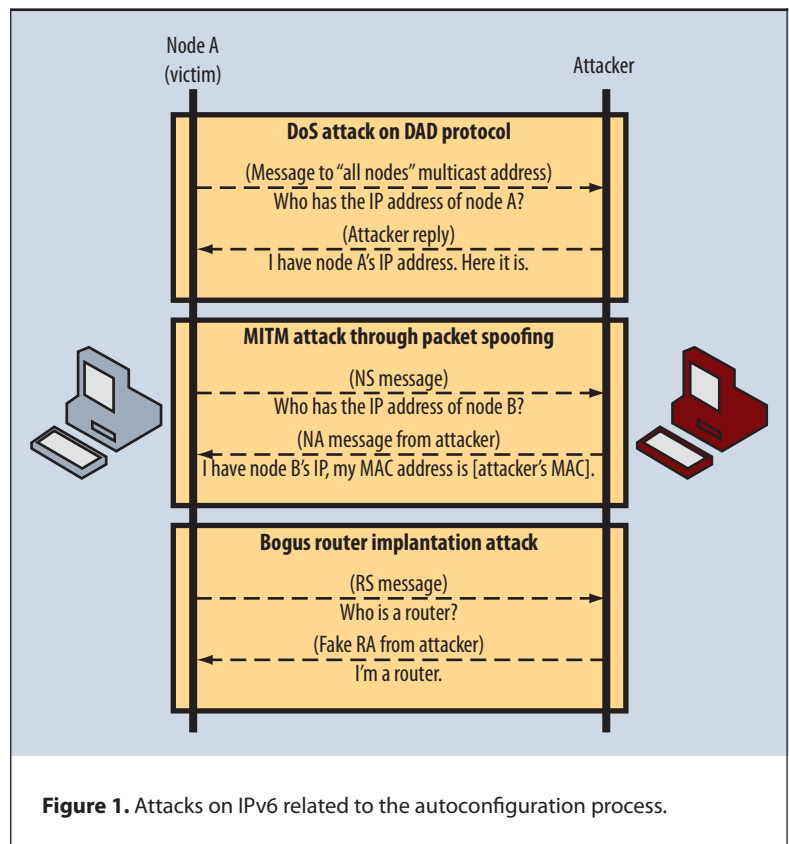


Figure 1. Attacks on IPv6 related to the autoconfiguration process.

members to leave.⁵ Because IPv6 eliminates broadcast addresses and uses multicast heavily, this kind of attack can seriously impede a node's operation. Also, as IPv6 has standard multicast addresses for important devices such as the "all routers" and "all DHCP servers" groups, an attacker can modify messages directed to these addresses on a network and receive information that helps identify key systems on which to target attacks.

SECURITY SOLUTIONS AND TOOLS

Several solutions and tools are available to deal with IPv6-related security problems.

SEND and CGAs

The Secure Neighbor Discovery protocol can counter some of the threats against the ND protocol when IPSec is not used.^{4,6} SEND uses *cryptographically generated addresses* to verify the sender's ownership of a claimed address. CGAs are IPv6 addresses in which part of the address is generated by applying a cryptographic one-way hash function based on a node's public key and auxiliary parameters. The hash value can then be used to verify the binding between the public key and a node's address.

By default, a SEND-enabled node should use only CGAs for its own addresses. The basic purpose of CGAs is to prevent the stealing or spoofing of existing IPv6 addresses. However, initially setting up CGAs can be a

problem as they themselves are not certified. Therefore, anyone could create a new CGA from inside a network segment that appears to be perfectly acceptable. The usefulness of this to an attacker is limited, but certification mechanisms for CGA addresses are essential for better security.

Packet filtering and firewall design

Basic IPv6 packet filtering can limit the effectiveness of simple reconnaissance attacks in IPv6 networks. However, because IPv6 depends heavily on ICMPv6 messages, any filtering of ICMPv6 packets should ensure that network functionality is not affected. Filtering schemes should consider the fact that a host with one network adapter card can have multiple IPv6 addresses. Adequate knowledge of an enterprise network's address ranges can mitigate address spoofing. This is accomplished by filtering packets with nonconformant addresses at the

IPv6 networks will operate in parallel with IPv4-based networks in many environments, possibly for a long time.

firewalls and blocking packets coming from outside the enterprise network that attempt to reach key network nodes through their multicast addresses.

Applying packet filters in IPv6 firewalls is more complicated than in IPv4 firewalls. The IPv6 packet structure definition allows for packets to contain several types of headers, and justifying and applying rules for each type of header will be burdensome. In addition, the packet structure makes IPv6 an extensible protocol that can incorporate new functionality with new headers, but attackers could exploit this capability for malicious purposes. This raises the dilemma of whether to allow or drop packets with unknown headers or options.

The development of IPv6 security appliances is in its initial stages. IPv6 firewall capabilities have been incorporated into several Linux variants and in equipment from manufacturers such as Cisco Systems and Juniper Networks.

IPv6 security-related tools

Many security monitoring and auditing tools lack IPv6 support, and the tools that exist are limited in their capabilities. Some open source tools that support IPv6 are

- THC-IPv6: a tool suite for attacking IPv6-based networks;
- Multi-Generator (MGEN), SendIP, Scapy6, and Ipv6Pack- etGen: tools for generating IPv6 packets/traffic;

- NDPWatch: keeps a database of Ethernet versus IPv6 address pairings and reports any changes to the pairings;
- Neighbor Discovery Protocol Monitor (NDPmon): monitors the local network and reports any suspicious ND messages;
- ddaddos: monitors a network to detect any DAD-based attack;
- Nmap: network vulnerability scanner;
- Snort: intrusion detection and prevention system;
- Wireshark: network protocol analyzer; and
- Netcat6: utility to read and write data across IPv6 network connections.

THC-IPv6 and SendIP have been particularly useful at generating attacks in our laboratory environment. In general, despite the limited number of IPv6 tools currently available, more will likely be developed as interest in IPv6 picks up.

DEPLOYMENT CHALLENGES

There are several security-related issues associated with transitioning to and deploying IPv6.

IPSec and key management

In general, proper use of IPSec would mitigate many of the attacks currently possible on an unsecured IPv6 network. The current protocol suite effectively secures well-defined communicating end points, but to secure arbitrary end-to-end communications, an adequate shared encryption key management infrastructure must be in place with the support of a protocol such as Internet Key Exchange. IKE facilitates establishment of encryption keys for IPSec services, but its various configuration options make it difficult for the communicating end points to negotiate the parameters for securing a particular traffic flow—establishing a security association—unless both have previously agreed on the options they support.

There is progress in developing automated key management methods and protocols, but scalability and manageability issues still plague their deployment. Thus, fully securing IPv6 networks with IPSec support remains a distant goal.⁷

Transition issues

Many of today's networks will not be able to turn off their IPv4 functionality and change to IPv6 at the flick of a switch. IPv6 networks will operate in parallel with IPv4-based networks in many environments, possibly for a long time. Hence, effective approaches are needed to gracefully migrate from IPv4 to IPv6 or to support their coexistence. Currently available approaches include protocol translation, traffic tunneling, and dual-stack systems.⁸

Protocol translation. This involves converting IPv4 packets to IPv6 packets, and vice versa, with the use of a protocol and address translation gateway. Translation techniques are not expected to be used widely because they significantly slow down packet flow. Further, they do not allow the network to exploit specific capabilities of either protocol.

Traffic tunneling. This involves encapsulating an IPv6 packet into an IPv4 packet when it goes through non-IPv6 routers, or vice versa. Traffic tunneling can raise serious security concerns if an IPv6-unaware firewall is used at an end point. When carrying IPv6 traffic over an IPv4 tunnel, the firewall rules will let IPv4 traffic through without examining the encapsulated IPv6 traffic, which could be anything including malicious packets.

In general, for establishing adequate policies for inbound and outbound traffic, static tunneling in which communicating end points are fixed is preferable to dynamic tunneling in which communicating end points are not predetermined. However, static tunneling introduces a severe burden as administrators must maintain the configuration of each of the tunnel's end points manually.

Dual-stack systems. Providing support for IPv4 and IPv6 traffic simultaneously will likely be the most popular approach. However, this requires managing the security configurations of both IPv4 and IPv6 infrastructures. In particular, configuring packet filter rules and access lists to provide the same level of protection for both will be difficult.

A crucial issue is that the two stacks' vulnerabilities will compound the attack surface, especially when IPSec is not used. In dual-stack networks, the firewalls and intrusion detection systems must support both IPv4 and IPv6. Mapping IPv4 addresses to IPv6 addresses could be one transition strategy. However, in such cases, firewall rules can be effective only if they are aware of the mapping semantics.

FUTURE RESEARCH

Several factors have made migration to IPv6 inevitable, including IPv4's insufficient address space and the growing need for a more secure Internet protocol. Early adopters have been documenting their successes and difficulties implementing IPv6. In general, IPv6 offers support for end-to-end communications, better performance, and improved quality of service. End-to-end communications in particular will facilitate the development of newer multimedia-based ubiquitous applications. At the same time, end-to-end communications will require the use of defense-in-depth mechanisms to protect networks. The realization of these benefits in the future Internet will depend on the proper understanding of IPv6 security

issues and on the tools available to support network/security management.

IPv6 security vulnerabilities

Researchers should adequately study and repair security vulnerabilities in IPv6 before they become widespread nuisances. While the attacks we describe here are specific to the protocol's new features, several other types of attacks can be launched on IPv6 networks using various tools (www.thc.org/thc-ipv6). However, most attacks localize their impact on the link to which the attacker node is attached. Thus, detecting rogue devices on a link is a key challenge in defending and securing IPv6 networks.

Further analysis of the vulnerabilities of each transition approach is also required to move IPv6 adoption forward and develop defense-in-depth strategies. For now, these strategies can be implemented by incorporat-

Several factors have made migration to IPv6 inevitable, including IPv4's insufficient address space and the growing need for a more secure Internet protocol.

ing firewalls with adequate packet filters for both IPv4 and IPv6 traffic, SEND and CGAs, and personal firewalls that support IPv6.

IPSec deployment and efficient key management

Although proper use of IPSec can mitigate several security problems, it is a complex set of protocols that poses deployment challenges. Further, IPSec relies heavily on a key-management infrastructure, and unless public-key infrastructure systems can be easily integrated into IPv6 networks, IPSec use will be limited, and the networks will remain vulnerable. Research in the design of platforms for more efficient key-management infrastructure implementations is necessary to ensure the successful deployment and use of IPv6.

IPv6 security and transition tools

More efficient and effective security tools to analyze IPv6 networks' vulnerabilities and weaknesses are needed to ensure the development of appropriate monitoring capabilities and effective proactive and reactive defense mechanisms, particularly in the areas of scanning and intrusion detection. Integrated tools to support security

administration of both IPv4 and IPv6 networks will facilitate dual-stack system implementations.

The cost implications of a secure transition to IPv6 are not well understood either. Proper planning to align the transition with an enterprise's IT upgrade/replace cycle and its defense-in-depth strategies is needed to ensure economic benefits. Several factors will affect costs, including network size, required quality of service, the transition mechanism used, and the level of protection needed during the transition.

The 6Net Consortium offers guidelines, with case studies, for incorporating IPv6 in both large (campus, enterprise) and small environments.⁹

Although several efforts are under way to develop new networking environments, such as the Global Environment of Network Innovations (<http://geni.net>), IPv6 has arrived and is here to stay as the next-generation Internet protocol—at least until a better and completely new global network replaces it. Given IPv6's growing importance, the development of techniques and tools to protect emerging IPv6-based networks is a current and pressing need. 

Acknowledgment

This work was supported by US National Science Foundation award IIS-0545912.

References

1. IPv6 Task Force, "Technical and Economic Assessment of Internet Protocol Version 6 (IPv6)," Jan. 2006, US Dept. of Commerce; www.ntia.doc.gov/ntiahome/ntiageneral/ipv6/final/ipv6finalTOC.htm.
2. G. Van de Velde et al., *Local Network Protection for IPv6*, IETF RFC 4684, May 2007; www.rfc-archive.org/getrfc.php?rfc=4864&tag=Local-Network-Protection-for-IPv6.
3. S. Convery and D. Miller, "IPv6 and IPv4 Threat Comparison and Best-Practice Evaluation (v1.0)," Mar. 2004; www.seanconvery.com/v6-v4-threats.pdf.
4. P. Nikander, J. Kempf, and E. Nordmark, *IPv6 Neighbor Discovery (ND) Trust Models and Threats*, IETF RFC 3756, May 2004; www.rfc-archive.org/getrfc.php?rfc=3756.
5. T. Doan, "IPv6 Security Assessment," 1 June 2006, SAIC; www.hpcmo.hpc.mil/Htdocs/DREN/2006SEP01_IPv6_SecurityAssessment.pdf.
6. J. Arrko et al., *SEcure Neighbor Discovery (SEND)*, IETF RFC 3971, Mar. 2005; www.rfc-archive.org/getrfc.php?rfc=3971.
7. A.F. Gómez-Skarmeta et al., "PKI Services for IPv6," *IEEE Internet Computing*, May/June 2003, pp. 36-42.
8. E. Davies, S. Krishnan, and P. Savola, *IPv6 Transition/Coexistence Security Considerations*, IETF RFC 4942, Sept. 2007; www.rfc-archive.org/getrfc.php?rfc=4942&tag=IPv6-Transition%2FCoexistence-Security-Considerations.
9. M. Dunmore, ed., *An IPv6 Deployment Guide*, 6NET Consortium, Sept. 2005; www.6net.org/book/deployment-guide.pdf.

Carlos E. Caicedo is a PhD candidate in the School of Information Sciences at the University of Pittsburgh. His research interests include security of data networks, technoeconomic issues in spectrum management, and next-generation mobile data environments. Caicedo received an MS in electrical engineering from the University of Texas at Austin. He is a member the IEEE Computer Society and the ACM. Contact him at ccaicedo@ieee.org.

James B.D. Joshi is an associate professor as well as cofounder and director of the Laboratory for Education and Research on Security Assured Information Systems (LERSAIS) in the School of Information Sciences at the University of Pittsburgh. His research interests include role-based access control, XML security, and secure interoperability. Joshi received a PhD in computer engineering from Purdue University. He is a member of the IEEE and the ACM. Contact him at jjoshi@sis.pitt.edu.

Summit R. Tuladhar is a software engineer for Ericsson. His research interests include network security, Mobile IPv6, and emerging access network technologies. Tuladhar received an MS in telecommunication from the University of Pittsburgh. He is a member of the IEEE. Contact him at summit@ieee.org.

Engineering and Applying the Internet

IEEE
Internet Computing

IEEE Internet Computing reports emerging tools, technologies, and applications implemented through the Internet to support a worldwide computing environment.

For submission information and author guidelines, please visit www.computer.org/internet/author.htm